

Phishing Awareness Analysis & Triage Toolkit

DecodeLabs Industrial Training | Project 3 Submission

1. The Phishing Triage Checklist

Use this non-expert checklist to systematically identify cognitive triggers and technical disguises in incoming communications.

- **Sender Anomaly Check:** Does the display name match the routing domain? Verify the underlying Return-Path.
- **Psychological Triggers:** Does the message rely on **Authority** (impersonating executives), **Urgency** (artificial time limits), or **Fear/Greed** (threats of locking accounts/unexpected prizes)?
- **Link Verification:** Hover over links before clicking. Look for combosquatting (e.g., company-secure-login.com), typosquatting, or nested subdomains (e.g., www.company.com.fake-update.com). Read URLs from right to left.
- **Contextual Integrity:** Is the request to bypass standard operating procedures (SOPs)? Are they asking for sensitive information (MFA codes, wire transfers) via an insecure channel?
- **Attachment Safety:** Check for anomalous file types like .iso, .js, or .scr that shouldn't be used in standard business documents.

2. Standard Operating Procedure: Header & URL Analysis

Parsing From/Return-Path Headers

Modern mobile clients often hide the true sender domain. Always expand the email headers. If the From: display name reads *"IT Support"* but the underlying address is *"admin@random-domain123.com"*, this is **Display Name Spoofing**.

Identifying Suspicious Subdomains

Threat actors use the "Subdomain Trap" to hide malicious sites. Instruct users to read URLs from **Right to Left** to find the true root domain. For example, in `www.decode labs . tech . login - update . com`, the true root domain is `login - update . com`, not `decode labs . tech`.

3. Incoming Threat Decision Tree

Every triage event must follow the **Pause, Verify, Report** methodology and end in one of these definitive actions:

Incoming Event: SAFE

Contextually sound, fully verified, no technical anomalies.

ACTION: Close

Incoming Event: SUSPICIOUS

Unusual urgency or request for sensitive info, but no obvious payload.

ACTION: Warn User
(Verify via out-of-band channel)

Incoming Event: MALICIOUS

Confirmed domain spoofing, dangerous attachments, or fake SSO prompts.

ACTION: Block & Escalate
(Purge from organization)

4. Sample Simulation Analysis

Below is an analysis of three distinct phishing vectors, highlighting keywords, red flags, and the rationale for classifying them as unsafe.

Sample 1: Business Email Compromise (Whaling)

From: CEO - STRICTLY CONFIDENTIAL <ceo.urgent@executive-update.com>
Subject: IMMEDIATE ACTION REQUIRED: Transfer Authorization
Date: August 26, 2026

URGENT: Process the attached wire transfer instruction immediately. This is critical and must remain STRICTLY CONFIDENTIAL. Do not discuss with anyone. Bypass standard procedure.

- **Suspicious Keywords:** "IMMEDIATE ACTION REQUIRED", "STRICTLY CONFIDENTIAL", "Bypass standard procedure".
- **Red Flags:** Sender-Domain mismatch (Display name implies CEO, domain is executive-update.com). Exploits Authority and Urgency cognitive triggers. Explicit demand for secrecy.
- **Why it is unsafe:** This is a targeted BEC (Business Email Compromise) attempt aiming to bypass finance department checks by isolating the employee and forcing an unauthorized wire transfer. **Triage: Malicious -> Block & Escalate.**

Sample 2: Credential Harvesting via SaaS Impersonation

From: IT Security <support@companyname-secure-login.com>
Subject: Mandatory: Password expires in 24 hrs

Your SSO password will expire in 24 hours. Please click the link below to verify your credentials and retain access to corporate services.

<https://portal.companyname-secure-login.com/auth>

- **Suspicious Links/Keywords:** "Password expires in 24 hrs" (Urgency), Link root domain is companyname-secure-login.com instead of the legitimate root domain.

- **Red Flags:** Combosquatting (appending "-secure-login" to a brand name). Creates a fear of missing out (FOMO) or losing access to force a quick, unthinking click.
- **Why it is unsafe:** This leads to a credential harvesting portal designed to steal the employee's Single Sign-On (SSO) credentials, compromising the corporate network. **Triage: Malicious -> Block & Escalate.**

Sample 3: Multi-Channel Callback Phishing (TOAD)

From: Microsoft Subscription Renewal <billing@ms-renewals-auto.com>
Subject: PAYMENT OVERDUE - Order #50012503

Your Microsoft Subscription Renewal is processing. Amount: \$150.00 .
If you did not authorize this charge, call 1-800-XXX-XXXX to cancel IMMEDIATELY.

- **Suspicious Links/Keywords:** "PAYMENT OVERDUE", "call 1-800-XXX-XXXX", "cancel IMMEDIATELY".
- **Red Flags:** Absence of digital links. Relies on the user calling the provided fictitious phone number out of panic over a fake charge (Telephone-Oriented Attack Delivery).
- **Why it is unsafe:** Calling the number routes the user to a fraudulent call center (Vishing) where attackers use social engineering to extract credit card details or persuade the user to install remote access malware. **Triage: Malicious -> Block & Escalate.**